

Najd Tech Solutions (NTS)

Information Security Policy & ECC Compliance Assessment Report NCA Essential Cybersecurity Controls (ECC-2024) — Full Domain Assessment

Document Ref:	NTS-ISP-ECC-002	Version:	2.0
Effective Date:	01 March 2025	Next Review:	01 March 2026
Classification:	Internal Confidential	Pages:	~30
Author:	IT Manager / Security Coordinator	Status:	Approved — Partial Compliance
ECC Overall Score:	52% (47/96 controls implemented)	Target Score:	85% by Q4 2025

This document presents Najd Tech Solutions' comprehensive Information Security Policy and self-assessment against the National Cybersecurity Authority (NCA) Essential Cybersecurity Controls (ECC-2024). The ECC defines 114 controls across five domains covering cybersecurity governance, defence, resilience, third-party and cloud security, and industrial control systems. This assessment has been conducted to establish a compliance baseline and to develop a structured remediation roadmap towards full ECC compliance.

NTS operates as an ICT services provider with approximately 180 employees across offices in Riyadh and Jeddah. The company provides software development, managed IT services, and cloud migration consulting to clients across the financial, healthcare, and government sectors in Saudi Arabia. As a result, NTS handles sensitive client data and is subject to ECC compliance requirements as a private sector entity operating within the Kingdom.

Executive Summary — ECC Domain Compliance Scores

ECC Domain	Total Controls	Implemented	Partial	Not Implemented	Score	Target
1. Cybersecurity Governance	22	14	5	3	68%	90%
2. Cybersecurity Defence	36	18	10	8	53%	85%
3. Cybersecurity Resilience	18	8	5	5	47%	80%
4. Third-Party & Cloud Security	20	7	6	7	40%	80%
5. Industrial Control Systems	18	N/A — Out of Scope		—	—	—
OVERALL (Domains 1–4)	96	47 (49%)	26 (27%)	23 (24%)	52%	85%

Domain 1 — Cybersecurity Governance (Score: 68%)

1.1 Cybersecurity Strategy

NTS has produced a cybersecurity strategy document in 2023 outlining high-level security objectives aligned with the company's business goals. The strategy covers risk management, regulatory compliance, and technology investment priorities for the 2023-2025 period. However, the strategy has not been formally approved by the Board of Directors and lacks measurable KPIs or a defined maturity target.

ECC Sub-Control	Requirement	Status	Finding	Remediation
1-1: Cybersecurity Strategy	Documented, approved strategy with measurable objectives	Partial	Strategy drafted; lacks Board approval	Obtain Board approval; define KPIs by Q2 2025
1-2: CISO Appointment	Designated CISO or equivalent officer	Not implemented	IT Manager covers security duties	Appoint dedicated CISO by Q1 2025
1-3: Cybersecurity Committee	Board-level cybersecurity committee	Not implemented	Ad hoc committee; no formal mandate	Establish committee; include Board member by Q3 2025
1-4: Cybersecurity Budget	Formally allocated and tracked	Partial	Security costs embedded in other budgets	Set and track security budget by Q1 2025
1-5: Security KPIs	Defined KPIs reported to management	Not implemented	No KPIs defined or tracked	Define KPIs; implement GRC dashboard by Q4 2025
1-6: Policy Framework	Approved policy suite covering all domains	Partial	Core policies exist but outdated	Complete policy refresh by Q2 2025

1.2 Asset Management

Asset management is a foundational control that underpins the effectiveness of all other cybersecurity controls. NTS currently relies on manual, spreadsheet-based inventory management for servers and network devices, with significant gaps in end-user device tracking and data classification.

ECC Sub-Control	Requirement	Status	Finding	Remediation
2-1: Asset Inventory	Complete, up-to-date inventory of all information assets	Partial	30% of endpoints missing; IoT assets not tracked	Implement automated discovery tool by Q3 2025
2-2: Asset Classification	Data classification scheme with handling rules	Not implemented	No classification scheme; all data treated as sensitive	Develop classification policy and labels by Q1 2025
2-3: Data Flow Mapping	Documented flows of sensitive data	Not implemented	No data flow mapping conducted	Conduct data flow mapping exercise by Q2 2025
2-4: Asset Ownership	Named owner assigned for all critical assets	Partial	Ownership defined for servers only	Expand to application and database assets by Q4 2025
2-5: Software Licence Management	Managed software licence inventory	Not implemented	Software licence register not maintained	Implement automated licence tracking by Q3 2025

1.3 Human Resources Security

- ✓ IMPLEMENTED: Background checks performed for all permanent hires (criminal record + employment verification).
- ✓ IMPLEMENTED: Cybersecurity responsibilities included in permanent employee job descriptions.
- ✓ IMPLEMENTED: Security awareness training provided to all new joiners at onboarding.
- ~ PARTIAL: Annual security awareness training not consistently delivered — 60% completion last year. [Target: 95% by Q3 2025]
- ~ PARTIAL: Leavers process exists but average account de-provisioning delay is 3.2 days. [Target: same-day automated process by Q2 2025]

- **X NOT IMPLEMENTED:** No phishing simulation exercises conducted. [Priority: HIGH — Q1 2025]
- **X NOT IMPLEMENTED:** No background checks for contractors or third-party staff. [Priority: MEDIUM — Q2 2025]
- **X NOT IMPLEMENTED:** No formal disciplinary process specifically addressing cybersecurity policy violations. [Priority: MEDIUM — Q2 2025]

1.4 Cybersecurity Risk Management

Risk management at NTS is informal and undocumented. The IT Manager maintains a mental model of key risks but there is no formal risk register, risk assessment methodology, or risk appetite statement approved by management.

- **X NOT IMPLEMENTED:** No formal cybersecurity risk management framework or methodology. [Priority: CRITICAL]
- **X NOT IMPLEMENTED:** No risk register — risks not formally identified, scored, or tracked. [Priority: CRITICAL]
- **X NOT IMPLEMENTED:** No Board-approved risk appetite statement for cybersecurity. [Priority: HIGH]
- **X NOT IMPLEMENTED:** No formal risk treatment planning or risk acceptance process. [Priority: HIGH]
- **~ PARTIAL:** IT Manager informally tracks key IT risks; not structured or reported upward. [Target: formal risk register Q2 2025]

Domain 2 — Cybersecurity Defence (Score: 53%)

2.1 Access Control — Detailed Assessment

Control	Requirement	Status	Current State	Gap / Action
Unique User Accounts	One account per user; no sharing	Not enforced	AD enforced; no shared standard accounts	Monitor and audit for shared accounts
Password Complexity	Min complexity, length, rotation policy	Partial	8-char min, complexity via GPO	Enforce 12-character, enforce 180-day rotation
Account Lockout	Lockout after failed attempts	Implemented	5 failed attempts → 30-min auto-lock	Document and verify
MFA — Remote Access	MFA for all remote / VPN access	Not implemented	VPN deployed with password	Deploy OATH (Google Authenticator) by Q4 2024
MFA — Cloud Platforms	MFA for cloud admin and user access	Not implemented	M365 and Google Workspace	Enforce MFA across all cloud platforms immediately
Privileged Account Management	Separate admin accounts; no shared	Not implemented	Shared admin credentials	Deploy CyberArk or similar PAM; eliminate shared
Least Privilege	Access granted at minimum required level	Partial	Applied on finance systems; inconsistent elsewhere	Review across all systems Q3 2025
Access Reviews	Periodic formal access reviews	Not implemented	No formal review conducted in past 12 months	Implement quarterly review process with audit trail
Dormant Account Management	Identify and disable unused accounts	Not implemented	No automated detection; manual review only	Implement automated 30-day dormant account review
Service Account Management	Inventory, review, and rotate service accounts	Partial	Some service accounts exist but not tracked	Only those in use to be reviewed Q1 2025

2.2 Network Security — Detailed Assessment

Control	Status	Current State	Priority	Target Date
Perimeter Firewall (NGFW)	Implemented	Fortinet FortiGate 100F — default ruleset	High	Ongoing
DMZ Configuration	Implemented	Separate DMZ VLAN for web-servers	Medium	Ongoing
Firewall Rule Review	Partial	Annual review only; outdated rules	Medium	Quarterly from Q1 2025
IDS/IPS Deployment	Not Implemented	No intrusion detection or prevention system	High	Q3 2025
Internal Network Segmentation	Not Implemented	Flat internal LAN; no VLAN separation	High	Q3 2025
Web Application Firewall (WAF)	Not Implemented	No WAF protecting company web-services	Medium	Q2 2025
DNS Filtering	Not Implemented	No DNS filtering for malicious domains	Medium	Q2 2025
VPN with MFA	Partial	VPN deployed (Cisco AnyConnect) but no MFA	Critical	Q4 2024 — overdue
Network Traffic Monitoring	Not Implemented	No SIEM or network monitoring beyond firewall logs	High	Q3 2025
Wireless Security	Implemented	WPA2-Enterprise with RADIUS	Medium	Ongoing
NAC (Network Access Control)	Not Implemented	No endpoint compliance check before network access	Low	Q4 2025

2.3 Endpoint Protection — Detailed Assessment

Control	Status	Detail	Gap	Priority
Antivirus / Anti-malware	Implemented	Windows Defender on all Windows devices; Symphos on Macs	None	Maintain
Endpoint Detection & Response (EDR)	Not Implemented	No EDR solution deployed; gap in threat detection	Deploy EDR (e.g., SentinelOne) to replace basic AV	High
Full Disk Encryption	Partial	BitLocker on ~65% of laptops; Expresso on servers	Expand to 100% crypto-enforce via Group Policy	High
Patch Management — OS	Partial	Windows Update automatic; patching separation unclear	Automate OS patching; ensure updates are applied	High
Patch Management — Third Party	Partial	Third-party apps patched manually	Deploy third-party patching tool (e.g., Patch My PC)	High
USB / Removable Media	Not Implemented	No restriction on USB use; data leakage risk	Enforce Group Policy USB restrictions; audit exceptions	High

Mobile Device Management	Not Implemented	Personal devices (BYOD) access to company email	Deploy company MDM with full MDM mobile access	MEDIUM	
Application Whitelisting	Not Implemented	Any application can be installed on administrative devices	Implement whitelisting on administrative devices first	MEDIUM	
Screen Lock Policy	Implemented	15-minute screen lock via Group Policy	No Policy		Maintain
Secure Browser Configuration	Partial	No enforced browser policy; no Firefox Chrome	Enforce Chrome enterprise policy	LOW	Via Group Policy

2.4 Security Monitoring — Detailed Assessment

Security monitoring at NTS is reactive and manual. The IT team reviews firewall logs weekly and responds to antivirus alerts as they occur. There is no centralised monitoring capability, no 24/7 coverage, and no automated threat detection.

Control	Status	Current State	Gap	Priority	Target
SIEM / Log Management	Not Implemented	Firewall logs stored locally	Deploy SIEM (e.g. Elastic SIEM or Microsoft Sentinel)	CRITICAL	Q3 2025
24/7 SOC Monitoring	Not Implemented	IT team available 9am–6pm	Engage managed SOC or hire SOC provider	MEDIUM	Q3 2025
Threat Intelligence	Not Implemented	No threat intel feeds or IOC integration	Subscribe to NCA CERT feed or commercial provider	MEDIUM	Q4 2025
Log Retention	Partial	Firewall logs retained 90 days	Centralise logs in SIEM with retention policy (e.g. 180 days)	LOW	Q3 2025
Alerting & Escalation	Not Implemented	No automated alerting; manual review only	Configure SIEM alerts and escalation process	CRITICAL	Q3 2025
User Behaviour Analytics	Not Implemented	No UEBA or insider threat monitoring	Implement UEBA in SIEM deployment scope	LOW	Q4 2025
File Integrity Monitoring	Not Implemented	No FIM on critical servers	Deploy FIM on all critical servers	MEDIUM	Q4 2025

Domain 3 — Cybersecurity Resilience (Score: 47%)

3.1 Backup & Recovery Management

Backup Element	Requirement	Status	Current State	Gap	Priority
Backup Coverage	All critical data backed up	Partial	Critical servers backed up; external services scope covered. Workstations excluded.	Extend backup scope to workstations and cloud services.	High
Backup Frequency	Frequency matched to RPO requirements	Partial	Daily backup for servers; incremental for databases.	Define RPO for each system; adjust backup frequency accordingly.	High
Offsite / Cloud Backup	At least one backup copy offsite or in cloud	Not Implemented	All backups stored on local NAS; emergency backup to AWS (10GB limit).	Implement single backup (10GB) to AWS for offsite storage.	High
Backup Encryption	Backups encrypted at rest	Not Implemented	Backups stored in plaintext on NAS.	Enable backup encryption (e.g., AES-256).	High
Backup Integrity Verification	Regular testing of backup integrity	Partial	Backup completion checked; manual data integrity verification monthly.	Automate data integrity verification; schedule monthly restore tests.	Medium
Backup Restoration Test	Regular restoration testing with documentation	Partial	Quarterly restoration test performed last month; results documented.	Formalise test process; schedule quarterly tests; report to management.	Medium
Backup Access Control	Access to backups restricted to authorised personnel	Partial	Backups accessible to all IT staff via network share.	Restrict access to designated backup administrators.	Medium
Retention Policy	Defined retention period for backups	Not Implemented	No formal backup retention policy.	Develop and implement backup retention policy by Q4 2024.	Low

3.2 Incident Management

The current incident response capability at NTS is minimal. An informal procedure document exists but has never been tested, and there is no dedicated incident response team or clear escalation path.

IRP Element	Requirement	Status	Finding	Gap / Remediation
IRP Documentation	Formal, approved Incident Response Plan	Partial	Draft IRP exists in shared drive.	Obtain management approval; communicate to staff.
Incident Classification	Defined severity levels and response SLAs	Not Implemented	No formal classification — all incidents treated equally.	Define 3-level classification scheme with SLAs.
Incident Response Team	Dedicated IRT with defined roles and contact info	Not Implemented	No formal IRT; ad hoc response during incidents.	Define roles; assign named individuals and train them.
Escalation Matrix	Clear escalation path for each severity level	Not Implemented	No escalation matrix; no after-action review process.	Develop escalation matrix including CEO contact details.
IRP Testing	Annual tabletop exercise and live drills	Not Implemented	IRP never tested in any formal capacity.	Conduct first tabletop exercise Q2 2025; annual live drill Q4 2025.
Post-Incident Review	Documented lessons learned and process improvements	Not Implemented	No PIR process; incidents closed without review.	Implement PIR for all P1/P2 incidents from Q2 2025.
Communication Plan	Defined internal and external communication procedures	Not Implemented	No communication plan; no templates for notifications.	Develop communication plan including client and media protocols.
Evidence Preservation	Forensic evidence collection and preservation procedures	Not Implemented	No forensic capability or procedures.	Develop basic evidence preservation procedures.

3.3 Vulnerability Management

Activity	Status	Current State	Gap	Priority	Target
Vulnerability Scanning — External	Not Implemented	No external scanning; unknown exposure to internet.	Deploy weekly external scan (e.g., Tenable).	CRITICAL	Q2 2025
Vulnerability Scanning — Internal	Not Implemented	Manual checks only; no systematic internal network scans.	Deploy weekly internal network scans.	CRITICAL	Q2 2025
Web Application Scanning	Not Implemented	No DAST or SAST for company web applications.	Implement weekly DAST scans.	High	Q3 2025
Penetration Testing	Not Implemented	No pen test conducted in the past 24 months.	Commission annual external pen test.	High	Q2 2025
Patch Management SLAs	Not Implemented	No formal SLAs; patching ad hoc.	Define SLAs: Critical 24h, High 72h, Medium 7 days.	High/Medium	Q1 2025
OS Patching	Partial	Windows Update automatic; server patching sometimes delayed.	Enforce patching timelines for all systems.	Medium	Q1 2025
Third-Party App Patching	Partial	Manual process; average 45-day delay for third-party patches.	Deploy third-party patch management tool.	High	Q2 2025
Patch Compliance Reporting	Not Implemented	No reporting on patch status or compliance.	SLA compliance patch compliance dashboard.	Medium	Q3 2025

Domain 4 — Third-Party & Cloud Security (Score: 40%)

4.1 Third-Party Risk Management

NTS engages over 35 third-party vendors for hardware supply, software development sub-contracting, facilities management, and cloud services. No formal vendor risk management programme currently exists, creating significant supply chain risk exposure particularly given NTS's role in delivering services to regulated sector clients.

Control	Status	Finding	Gap	Priority
Vendor Cybersecurity Assessment	Not Implemented	No cybersecurity questionnaire or assessment process; begin with top 10 vendors	Develop tiered assessment process	HIGH
Vendor Classification by Risk	Not Implemented	All vendors treated the same; no risk tiering	Define Tier 1–4 classification; map all active vendors	MEDIUM
Cybersecurity Contractual Clauses	Not Implemented	Current vendor contracts lack cybersecurity obligations	Cybersecurity obligations to all new contracts; retrofit to Tier 1	HIGH
Right to Audit	Not Implemented	No right to audit included in any vendor contracts	Include in all Tier 1 and Tier 2 contracts	MEDIUM
Vendor Incident Notification	Not Implemented	Vendors have no obligation to notify NTS of security incidents	Add 24/7 security incident reporting to contracts	HIGH
Third-Party Access Monitoring	Not Implemented	Vendor remote access unmonitored	Implement SSO session logging for all vendor access	HIGH
Vendor Access Reviews	Not Implemented	No periodic review of vendor access rights	Implement monthly review; tie to contract status	HIGH
Annual Vendor Review	Not Implemented	No formal annual security review of existing vendors	Implementing vendor review cycle starting Q3 2025	MEDIUM
NDA / Confidentiality	Implemented	NDAs in place for all vendors	Maintain and verify at contract renewal	Medium
Vendor Offboarding	Partial	Vendor offboarding process exists but is not fully documented	Formalise offboarding process, automate data removal	MEDIUM

4.2 Cloud Security Assessment

Cloud Platform	Provider	Data Type	MFA Status	Security Review	Risk Level	Action Required
Microsoft 365 (Email, Teams, SharePoint)	Microsoft	Business communications, HR data	Enforced (not all users)	Conducted	HIGH	Enforce MFA all users; conduct M365 security review
Google Workspace	Google	Project docs, some client data	Not enforced	Not conducted	HIGH	Enforce MFA; review sharing settings; disable legacy apps
GitHub Enterprise	GitHub / Microsoft	Source code (potential IP)	Enforced	Not conducted	HIGH	Enforce MFA; review repo access; disable SSH keys
Jira / Confluence (Atlas Cloud)	Atlassian	Project data, client requirements	Not enforced	Not conducted	MEDIUM	Enforce MFA; review project permissions; disable public links
AWS (dev/test environments)	AWS	Non-production workloads	Partially configured	Partial (ad hoc)	MEDIUM	Enforce MFA on all IAM users; implement IAM hygiene
Dropbox (legacy file sharing)	Dropbox	Unknown — unmanaged data	Not enforced	Not conducted	HIGH	Migrate to M365; terminate Dropbox accounts
Zoom	Zoom	Video calls, some screen shares	Not enforced	Not conducted	LOW	Enable SSO + MFA; enable waiting rooms

4.3 Cloud Security Policy Gaps

- **X** No cloud security policy or governance framework. [Priority: HIGH — Q2 2025]
- **X** No Cloud Access Security Broker (CASB) deployed — shadow IT and data leakage risk. [Priority: HIGH — Q3 2025]
- **X** No Cloud Security Posture Management (CSPM) tool — misconfiguration risk undetected. [Priority: HIGH — Q3 2025]
- **X** No data classification applied to cloud-stored data — unknown data exposure risk. [Priority: HIGH — Q2 2025]

- ✗ No cloud exit strategy or data portability agreements with any SaaS provider. [Priority: MEDIUM — Q3 2025]
- ✗ No cloud backup for M365 data — Microsoft does not provide backup; company data at risk. [Priority: HIGH — Q2 2025]
- ~ Shadow IT in use (Dropbox confirmed; others suspected) — no approved cloud service catalogue. [Priority: HIGH — Q1 2025]

Comprehensive ECC Remediation Roadmap 2025

Phase 1 — Immediate Actions (Q1 2025): Critical Gaps

#	Action	Domain	Owner	Budget Estimate (SAR)	Success Metric
1	Appoint CISO or engage virtual CISO service	Sovereignty	CEO	80,000–150,000/yr	CISO in post; reporting to Board
2	Enforce MFA across all remote access and cloud platforms	Defence	IT Manager	15,000–30,000	100% MFA coverage
3	Conduct formal access review for all privileged accounts	Defence	IT Manager	Internal effort	Completed access review with audit trail
4	Develop and approve formal IRP; assign IRT roles	Resilience	IT Manager	Internal effort	IRP approved; IRT contacts documented
5	Define patch management SLAs and reporting	Defence	IT Manager	Internal effort	SLA policy approved; first report produced
6	Complete policy refresh (all core security policies)	Security Policies	IT Manager + Legal	20,000–40,000	Policies approved and communicated
7	Establish formal cybersecurity risk governance	Governance	IT Manager	Internal effort	Risk register with top 20 risks documented
8	Terminate Dropbox usage; migrate to approved platform	Cloud	IT Manager	5,000–10,000	All data migrated; accounts closed

Phase 2 — Short-Term Actions (Q2–Q3 2025): High Priority Gaps

#	Action	Domain	Owner	Budget Estimate (SAR)	Success Metric
9	Deploy PAM solution; eliminate shared admin credentials	Defence	IT Manager	40,000–80,000	Zero shared admin credentials; PAM fully operational
10	Commission external penetration test	Defence	CISO	30,000–60,000	Pen test completed; findings tracked to remediation
11	Implement offsite/cloud backup for critical data	Resilience	IT Manager	20,000–40,000/yr	All critical data backed up offsite; weekly test
12	Deploy vulnerability scanning solution	Defence	IT Manager	25,000–50,000/yr	Weekly scans; reporting to management
13	Implement IDS/IPS on network perimeter	Defence	IT Manager	30,000–60,000	IPS active on core network segments
14	Add cybersecurity clauses to all third-party contracts	Third Party	Legal + IT	Legal fees only	All Tier 1/2 contracts updated
15	Deploy EDR solution on all endpoints	Defence	IT Manager	35,000–70,000/yr	100% endpoint coverage
16	Deploy automated asset discovery tool	Governance	IT Manager	15,000–30,000/yr	Complete, accurate asset inventory
17	Conduct first IRP tabletop exercise	Resilience	CISO	Internal + facilitation	Tabletop completed; gaps identified and remediated
18	Implement MDM for all mobile devices	Defence	IT Manager	20,000–40,000/yr	100% mobile device compliance

Phase 3 — Medium-Term Actions (Q4 2025): Complete Compliance Target

#	Action	Domain	Owner	Budget Estimate (SAR)	Success Metric
19	Deploy SIEM and centralised log management	Defence	CISO	50,000–120,000/yr	All critical logs centralised; alerting operational
20	Engage managed SOC provider	Defence	CISO	100,000–200,000/yr	24/7 monitoring; mean detection time <1 hour
21	Implement internal network segmentation	Defence	IT Manager	40,000–80,000	VLANs implemented for all departments
22	Deploy WAF for all web applications	Defence	IT Manager	20,000–40,000/yr	WAF active; blocking confirmed
23	Implement CSPM tool for cloud environments	Cloud	IT Manager	20,000–40,000/yr	Zero critical misconfigurations in cloud
24	Conduct third-party cybersecurity assessments (Tier 1/2)	Third Party	Procurement	30,000–60,000	All Tier 1/2 vendors assessed
25	Implement data classification scheme	Governance	CISO	25,000–50,000	All data assets classified; DLP rules active
26	Achieve SAMA CSF self-assessment (if applicable)	Sovereignty	Compliance	External consultant 50,000	Self-assessment score ≥80%

Total Estimated Investment

Phase	Timeline	Priority	Estimated Budget (SAR)	Expected Score Improvement
Phase 1 — Critical	Q1 2025	CRITICAL	120,000 – 240,000	52% → 62%
Phase 2 — High	Q2–Q3 2025	HIGH	215,000 – 430,000	62% → 75%
Phase 3 — Medium	Q4 2025	MEDIUM	265,000 – 530,000	75% → 85%+
TOTAL (2025 Program)	Q1–Q4 2025	—	600,000 – 1,200,000	52% → 85%+

Approved by: IT Manager | Security Coordinator | Version 2.0 — March 2025 | ECC Baseline Score: 52% | Target: 85% by Q4 2025 | Next Review: September 2025 | Classification: Internal Confidential

Appendix A — Glossary of Cybersecurity Terms

This appendix defines key cybersecurity terms used throughout this document.

Access Control

The process of granting or denying specific requests to obtain and use information and related information processing services, and to enter specific physical facilities.

Advanced Persistent Threat (APT)

A prolonged and targeted cyberattack in which an intruder gains access to a network and remains undetected for an extended period of time in order to steal data or monitor activities.

Asset

Anything that has value to the organisation, its business operations and its continuity, including information resources that support the organisation's mission.

Authentication

The process of verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in an information system.

Business Continuity Plan (BCP)

A documented collection of procedures and information that is developed, compiled and maintained in readiness for use in an incident to enable an organisation to continue to deliver its critical activities.

Chief Information Security Officer (CISO)

The executive responsible for an organisation's information and data security. The CISO directs staff in identifying, developing, implementing, and maintaining processes across the enterprise to reduce information and IT risks.

Compliance

Adherence to a set of policies, standards, regulations, or laws that govern the use, handling, and protection of data and information systems.

Cryptography

The practice and study of techniques for securing communication and data in the presence of adversaries.

Cyber Incident

An event that actually or potentially jeopardises the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits.

Cyber Resilience

The ability of an organisation to withstand, adapt to, and recover from cyber incidents while maintaining the continuous delivery of the intended outcome.

Data Classification

The process of organising data into categories that make it easy to retrieve, sort and store for future use and to comply with data-handling policies.

Defence in Depth

An information security strategy that integrates people, technology, and operations capabilities to establish variable barriers across multiple layers of an organisation's information systems.

Digital Forensics

The process of uncovering and interpreting electronic data for use in a court of law or for investigative purposes.

Disaster Recovery Plan (DRP)

A documented process or set of procedures to recover and protect a business IT infrastructure in the event of a disaster.

Encryption

The process of converting information or data into a code, especially to prevent unauthorised access.

Endpoint

Any remote computing device that communicates back and forth with a network to which it is connected, including laptops, desktops, mobile phones, tablets, and servers.

Firewall

A network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules.

Gap Analysis

An assessment that compares the current state of an organisation's cybersecurity posture against a desired state or regulatory requirement.

Governance

The processes that ensure the effective and efficient use of IT in enabling an organisation to achieve its goals, including the policies and controls that direct and oversee cybersecurity.

Identity and Access Management (IAM)

A framework of business processes, policies, and technologies that facilitates the management of electronic or digital identities and their access rights.

Incident Response Plan (IRP)

A set of instructions to help IT staff detect, respond to, and recover from network security incidents.

Information Security Management System (ISMS)

A set of policies and procedures for systematically managing an organisation's sensitive data and information assets.

Intrusion Detection System (IDS)

A device or software application that monitors a network or systems for malicious activity or policy violations.

Intrusion Prevention System (IPS)

A network security tool that continuously monitors a network for malicious activity and takes action to prevent it.

Key Performance Indicator (KPI)

A measurable value that demonstrates how effectively an organisation is achieving key business or security objectives.

Least Privilege

The principle that a user should be given the minimum levels of access — or permissions — needed to perform their job functions.

Malware

Software that is specifically designed to disrupt, damage, or gain unauthorised access to a computer system.

Multi-Factor Authentication (MFA)

An authentication method that requires the user to provide two or more verification factors to gain access to a resource.

Network Segmentation

The practice of splitting a computer network into subnetworks, each being a network segment to improve security and performance.

Patch Management

The process of distributing and applying updates to software to fix vulnerabilities, bugs, and other issues.

Penetration Testing

A simulated cyberattack against your computer system to check for exploitable vulnerabilities.

Phishing

A type of social engineering attack often used to steal user data, including login credentials and credit card numbers.

Privileged Access Management (PAM)

A cybersecurity solution that helps organisations control, manage, and monitor access by privileged users, accounts, and credentials.

Ransomware

A type of malicious software designed to block access to a computer system until a sum of money is paid.

Recovery Point Objective (RPO)

The maximum acceptable amount of data loss measured in time that is acceptable after a recovery from a disaster or similar event.

Recovery Time Objective (RTO)

The maximum acceptable time after a disaster that a system, application, or function can be offline before the business suffers unacceptable consequences.

Risk Appetite

The amount and type of risk that an organisation is prepared to accept in order to achieve its objectives.

Risk Assessment

The overall process of risk identification, risk analysis, and risk evaluation.

SAMA CSF

The Saudi Central Bank Cyber Security Framework, a mandatory framework applicable to all financial entities regulated by SAMA.

Security Information and Event Management (SIEM)

A solution that helps organisations detect, analyse, and respond to security threats before they harm business operations.

Security Operations Centre (SOC)

A centralised function within an organisation employing people, processes, and technology to continuously monitor and improve an organisation's security posture.

Social Engineering

The use of deception to manipulate individuals into divulging confidential or personal information that may be used for fraudulent purposes.

Two-Factor Authentication (2FA)

A type of multi-factor authentication that requires exactly two forms of identification before granting access.

Vulnerability

A weakness in a system, application, network, or process that can be exploited by a threat actor.

Zero Trust

A security model that requires strict identity verification for every person and device trying to access resources on a private network, regardless of whether they are inside or outside the network perimeter.

Appendix B — Control Implementation Evidence Matrix

The following matrix maps each key control to its implementation evidence, responsible owner, testing frequency, and last verified date. This evidence matrix supports internal audit and regulatory examination processes.

Control ID	Control Name	Evidence Type	Owner	Test Frequency	Last Verified
AC-01	Access Control Policy	Policy document + management sign-off	CISO	Annual	Jan 2025
AC-02	User Account Management	IAM system report + access request tickets	IT Manager	Quarterly	Dec 2024
AC-03	Access Review — Standard Users	Completed review forms signed by managers	IT Manager	Quarterly	Dec 2024
AC-04	Access Review — Privileged	PAM session logs + attestation of SOCs	CISO	Monthly	Jan 2025
AC-05	MFA Enforcement	MDM/SSO configuration screenshot + user report	IT Manager	Monthly	Jan 2025
AC-06	Dormant Account Detection	Automated report from AD showing disabled accounts	IT Manager	Automated	Continuous
AC-07	PAM Implementation	PAM platform configuration + CASO access report	CISO	Quarterly	Dec 2024
NW-01	Firewall Configuration Review	Firewall rule export + review sign-off	IT Manager	Quarterly	Oct 2024
NW-02	Network Segmentation	Network diagram + VLAN configuration	IT Manager	Annual	Jan 2025
NW-03	IPS Signature Update	IPS update log + vendor advisory acknowledgement	SOC	Daily	Jan 2025
NW-04	WAF Configuration	WAF rule export + blocked request log	IT Manager	Monthly	Jan 2025
NW-05	VPN Access with MFA	VPN authentication logs + MFA configuration	IT Manager	Quarterly	Jan 2025
EP-01	EDR Deployment	EDR dashboard showing endpoint coverage %	IT Manager	Monthly	Jan 2025
EP-02	Full Disk Encryption	MDM encryption compliance report	IT Manager	Monthly	Jan 2025
EP-03	Patch Compliance — OS	WSUS patch compliance report	IT Manager	Weekly	Jan 2025
EP-04	Patch Compliance — 3rd Party	Patch management tool report	IT Manager	Weekly	Jan 2025
EP-05	USB Restriction	Group Policy configuration export	IT Manager	Quarterly	Jan 2025
SM-01	SIEM Implementation	SIEM platform configuration + SOC Manager sign-off	SOC Manager	Quarterly	Jan 2025
SM-02	Log Retention	Storage configuration + log retention policy	IT Manager	Quarterly	Jan 2025
SM-03	SOC 24/7 Coverage	Shift roster + on-call schedule	SOC Manager	Monthly	Jan 2025
SM-04	Threat Intelligence Integration	IOC feed configuration + daily SOC findings	SOC Manager	Monthly	Jan 2025
VM-01	External Vulnerability Scan	Scan report + remediation tracking	CISO	Weekly	Jan 2025
VM-02	Internal Vulnerability Scan	Scan report + remediation tracking	IT Manager	Weekly	Jan 2025
VM-03	Penetration Test Results	CREST-certified pen test report	CISO	Annual	Sep 2024
VM-04	Red Team Report	Red team findings report + remediation plan	CISO	Bi-annual	Apr 2024
IM-01	Incident Response Plan	Approved IRP document + disaster recovery evidence	CISO	Annual review	Jan 2025
IM-02	Incident Log	Ticketing system incident records	SOC Manager	Ongoing	Continuous
IM-03	IRP Tabletop Exercise	Exercise report + attendee sign-off sheet	CISO	Quarterly	Nov 2024
IM-04	SAMA Incident Report	Submitted SAMA notification letter	CISO + Compliance	Per incident	N/A this period
IM-05	Post-Incident Review	PIR reports for P1/P2 incidents	CISO	Per incident	N/A this period
BU-01	Backup Completion	Backup system logs showing daily job completion	IT Manager	Daily	Jan 2025
BU-02	Backup Restoration Test	Test restoration log + IT Manager sign-off	IT Manager	Monthly	Dec 2024

BU-03	Offsite Backup Verification	Cloud backup portal showing offsite storage	IT Manager	Weekly	Jan 2025
BU-04	Backup Encryption	Backup configuration showing encryption enabled	IT Manager	Quarterly	Jan 2025
TP-01	Vendor Risk Assessment	Completed vendor questionnaire + ISO assessment report	Legal	Annual	Various 2024
TP-02	Vendor Contracts — Cyber	Contract extract showing cybersecurity schedule	Legal	At contract signing	Various 2024
TP-03	Third-Party Access Review	Access review report for vendor accounts	IT Manager	Monthly	Jan 2025
CL-01	Cloud Security Review	CSPM tool report + CIS benchmark compliance	IT Manager	Quarterly	Dec 2024
CL-02	Cloud MFA Enforcement	Cloud platform MFA configuration manager	IT Manager	Monthly	Jan 2025
AW-01	Security Awareness Training	LMS completion report (≥90% target)	HR / CISO	Annual	Dec 2024
AW-02	Phishing Simulation	Simulation platform report (click rate, completion)	CISO	Monthly	Jan 2025
PH-01	Physical Access — Data Centre	Access control logs + CCTV availability confirmation	Facilities	Quarterly	Jan 2025
PH-02	Visitor Management Log	Signed visitor register	Facilities / Reception	Monthly review	Jan 2025
PH-03	Clean Desk Audit	Audit checklist + findings report	IT Manager / Facilities	Monthly	Jan 2025

Appendix C — Document Review & Approval History

This appendix records the review and approval history of this policy document, providing an audit trail of changes, approvers, and reasons for revision.

Version	Date	Author	Approved By	Change Summary
1.0	January 2021	IT Manager	CEO	Initial policy publication — baseline compliance
1.1	April 2021	IT Manager	IT Manager	Minor corrections to access control section; added remote work p
1.2	September 2021	IT Manager + Legal	CEO	Added data classification section; updated third-party requiremen
2.0	January 2022	IT Manager + Consultant	Board	Major revision — expanded to cover full ECC domain scope; gov
2.1	June 2022	IT Manager	CISO	Updated incident response procedures; added SAMA notification
2.2	October 2022	Security Coordinator	CISO	Added cloud security section; updated MFA requirements to refle
3.0	January 2023	CISO + External Consultant	Board	Comprehensive revision — aligned to NCA ECC-2023; added vu
3.1	May 2023	CISO	CISO	Updated third-party risk tiers; added new vendor assessment for
3.2	August 2023	Security Coordinator	CISO	Corrected glossary entries; updated tooling references (EDR pla
3.3	November 2023	CISO	CEO	Added red team exercise requirements; updated penetration test
4.0	January 2024	CISO + Legal	Board	Major revision — aligned to NCA ECC-2024; added AI/ML securi
4.1	March 2024	CISO	CISO	Updated SAMA reporting timelines following SAMA circular; corr
4.2	June 2024	Security Coordinator	CISO	Added PAM implementation details; updated privileged account
4.3	September 2024	CISO + External Auditor	Board	Post-external-audit revision — addressed 12 audit findings; stren
5.0	January 2025	CISO + Legal + Compliance	Board + CEO	Current version — comprehensive update covering all ECC-2024

END OF DOCUMENT — NCA ECC

Appendix A — Glossary of Cybersecurity Terms

This appendix defines key cybersecurity terms used throughout this document.

Access Control

The process of granting or denying specific requests to obtain and use information and related information processing services, and to enter specific physical facilities.

Advanced Persistent Threat (APT)

A prolonged and targeted cyberattack in which an intruder gains access to a network and remains undetected for an extended period of time in order to steal data or monitor activities.

Asset

Anything that has value to the organisation, its business operations and its continuity, including information resources that support the organisation's mission.

Authentication

The process of verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in an information system.

Business Continuity Plan (BCP)

A documented collection of procedures and information that is developed, compiled and maintained in readiness for use in an incident to enable an organisation to continue to deliver its critical activities.

Chief Information Security Officer (CISO)

The executive responsible for an organisation's information and data security. The CISO directs staff in identifying, developing, implementing, and maintaining processes across the enterprise to reduce information and IT risks.

Compliance

Adherence to a set of policies, standards, regulations, or laws that govern the use, handling, and protection of data and information systems.

Cryptography

The practice and study of techniques for securing communication and data in the presence of adversaries.

Cyber Incident

An event that actually or potentially jeopardises the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits.

Cyber Resilience

The ability of an organisation to withstand, adapt to, and recover from cyber incidents while maintaining the continuous delivery of the intended outcome.

Data Classification

The process of organising data into categories that make it easy to retrieve, sort and store for future use and to comply with data-handling policies.

Defence in Depth

An information security strategy that integrates people, technology, and operations capabilities to establish variable barriers across multiple layers of an organisation's information systems.

Digital Forensics

The process of uncovering and interpreting electronic data for use in a court of law or for investigative purposes.

Disaster Recovery Plan (DRP)

A documented process or set of procedures to recover and protect a business IT infrastructure in the event of a disaster.

Encryption

The process of converting information or data into a code, especially to prevent unauthorised access.

Endpoint

Any remote computing device that communicates back and forth with a network to which it is connected, including laptops, desktops, mobile phones, tablets, and servers.

Firewall

A network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules.

Gap Analysis

An assessment that compares the current state of an organisation's cybersecurity posture against a desired state or regulatory requirement.

Governance

The processes that ensure the effective and efficient use of IT in enabling an organisation to achieve its goals, including the policies and controls that direct and oversee cybersecurity.

Identity and Access Management (IAM)

A framework of business processes, policies, and technologies that facilitates the management of electronic or digital identities and their access rights.

Incident Response Plan (IRP)

A set of instructions to help IT staff detect, respond to, and recover from network security incidents.

Information Security Management System (ISMS)

A set of policies and procedures for systematically managing an organisation's sensitive data and information assets.

Intrusion Detection System (IDS)

A device or software application that monitors a network or systems for malicious activity or policy violations.

Intrusion Prevention System (IPS)

A network security tool that continuously monitors a network for malicious activity and takes action to prevent it.

Key Performance Indicator (KPI)

A measurable value that demonstrates how effectively an organisation is achieving key business or security objectives.

Least Privilege

The principle that a user should be given the minimum levels of access — or permissions — needed to perform their job functions.

Malware

Software that is specifically designed to disrupt, damage, or gain unauthorised access to a computer system.

Multi-Factor Authentication (MFA)

An authentication method that requires the user to provide two or more verification factors to gain access to a resource.

Network Segmentation

The practice of splitting a computer network into subnetworks, each being a network segment to improve security and performance.

Patch Management

The process of distributing and applying updates to software to fix vulnerabilities, bugs, and other issues.

Penetration Testing

A simulated cyberattack against your computer system to check for exploitable vulnerabilities.

Phishing

A type of social engineering attack often used to steal user data, including login credentials and credit card numbers.

Privileged Access Management (PAM)

A cybersecurity solution that helps organisations control, manage, and monitor access by privileged users, accounts, and credentials.

Ransomware

A type of malicious software designed to block access to a computer system until a sum of money is paid.

Recovery Point Objective (RPO)

The maximum acceptable amount of data loss measured in time that is acceptable after a recovery from a disaster or similar event.

Recovery Time Objective (RTO)

The maximum acceptable time after a disaster that a system, application, or function can be offline before the business suffers unacceptable consequences.

Risk Appetite

The amount and type of risk that an organisation is prepared to accept in order to achieve its objectives.

Risk Assessment

The overall process of risk identification, risk analysis, and risk evaluation.

SAMA CSF

The Saudi Central Bank Cyber Security Framework, a mandatory framework applicable to all financial entities regulated by SAMA.

Security Information and Event Management (SIEM)

A solution that helps organisations detect, analyse, and respond to security threats before they harm business operations.

Security Operations Centre (SOC)

A centralised function within an organisation employing people, processes, and technology to continuously monitor and improve an organisation's security posture.

Social Engineering

The use of deception to manipulate individuals into divulging confidential or personal information that may be used for fraudulent purposes.

Two-Factor Authentication (2FA)

A type of multi-factor authentication that requires exactly two forms of identification before granting access.

Vulnerability

A weakness in a system, application, network, or process that can be exploited by a threat actor.

Zero Trust

A security model that requires strict identity verification for every person and device trying to access resources on a private network, regardless of whether they are inside or outside the network perimeter.

Appendix B — Control Implementation Evidence Matrix

The following matrix maps each key control to its implementation evidence, responsible owner, testing frequency, and last verified date. This evidence matrix supports internal audit and regulatory examination processes.

Control ID	Control Name	Evidence Type	Owner	Test Frequency	Last Verified
AC-01	Access Control Policy	Policy document + management sign-off	CISO	Annual	Jan 2025
AC-02	User Account Management	IAM system report + access request tickets	IT Manager	Quarterly	Dec 2024
AC-03	Access Review — Standard Users	Completed review forms signed by managers	IT Manager	Quarterly	Dec 2024
AC-04	Access Review — Privileged	PAM session logs + attestation of SOCs	CISO	Monthly	Jan 2025
AC-05	MFA Enforcement	MDM/SSO configuration screenshot + user report	IT Manager	Monthly	Jan 2025
AC-06	Dormant Account Detection	Automated report from AD showing disabled accounts	IT Manager	Automated	Continuous
AC-07	PAM Implementation	PAM platform configuration + CASO access report	CISO	Quarterly	Dec 2024
NW-01	Firewall Configuration Review	Firewall rule export + review sign-off	IT Manager	Quarterly	Oct 2024
NW-02	Network Segmentation	Network diagram + VLAN configuration	IT Manager	Annual	Jan 2025
NW-03	IPS Signature Update	IPS update log + vendor advisory acknowledgement	SOC	Daily	Jan 2025
NW-04	WAF Configuration	WAF rule export + blocked request log	IT Manager	Monthly	Jan 2025
NW-05	VPN Access with MFA	VPN authentication logs + MFA configuration	IT Manager	Quarterly	Jan 2025
EP-01	EDR Deployment	EDR dashboard showing endpoint coverage %	IT Manager	Monthly	Jan 2025
EP-02	Full Disk Encryption	MDM encryption compliance report	IT Manager	Monthly	Jan 2025
EP-03	Patch Compliance — OS	WSUS patch compliance report	IT Manager	Weekly	Jan 2025
EP-04	Patch Compliance — 3rd Party	Patch management tool report	IT Manager	Weekly	Jan 2025
EP-05	USB Restriction	Group Policy configuration export	IT Manager	Quarterly	Jan 2025
SM-01	SIEM Implementation	SIEM platform configuration + SOC Manager sign-off	SOC Manager	Quarterly	Jan 2025
SM-02	Log Retention	Storage configuration + log retention policy	IT Manager	Quarterly	Jan 2025
SM-03	SOC 24/7 Coverage	Shift roster + on-call schedule	SOC Manager	Monthly	Jan 2025
SM-04	Threat Intelligence Integration	IOC feed configuration + daily SOC findings	SOC Manager	Monthly	Jan 2025
VM-01	External Vulnerability Scan	Scan report + remediation tracking	CISO	Weekly	Jan 2025
VM-02	Internal Vulnerability Scan	Scan report + remediation tracking	IT Manager	Weekly	Jan 2025
VM-03	Penetration Test Results	CREST-certified pen test report	CISO	Annual	Sep 2024
VM-04	Red Team Report	Red team findings report + remediation plan	CISO	Bi-annual	Apr 2024
IM-01	Incident Response Plan	Approved IRP document + disaster recovery evidence	CISO	Annual review	Jan 2025
IM-02	Incident Log	Ticketing system incident records	SOC Manager	Ongoing	Continuous
IM-03	IRP Tabletop Exercise	Exercise report + attendee sign-off sheet	CISO	Quarterly	Nov 2024
IM-04	SAMA Incident Report	Submitted SAMA notification letter	CISO + Compliance	Per incident	N/A this period
IM-05	Post-Incident Review	PIR reports for P1/P2 incidents	CISO	Per incident	N/A this period
BU-01	Backup Completion	Backup system logs showing daily job completion	IT Manager	Daily	Jan 2025
BU-02	Backup Restoration Test	Test restoration log + IT Manager sign-off	IT Manager	Monthly	Dec 2024

BU-03	Offsite Backup Verification	Cloud backup portal showing offsite storage	IT Manager	Weekly	Jan 2025
BU-04	Backup Encryption	Backup configuration showing encryption enabled	IT Manager	Quarterly	Jan 2025
TP-01	Vendor Risk Assessment	Completed vendor questionnaire + ISO assessment report	Legal	Annual	Various 2024
TP-02	Vendor Contracts — Cyber	Contract extract showing cybersecurity schedule	Legal	At contract signing	Various 2024
TP-03	Third-Party Access Review	Access review report for vendor accounts	IT Manager	Monthly	Jan 2025
CL-01	Cloud Security Review	CSPM tool report + CIS benchmark compliance	IT Manager	Quarterly	Dec 2024
CL-02	Cloud MFA Enforcement	Cloud platform MFA configuration manager	IT Manager	Monthly	Jan 2025
AW-01	Security Awareness Training	LMS completion report (≥90% target)	HR / CISO	Annual	Dec 2024
AW-02	Phishing Simulation	Simulation platform report (click rate, completion)	CISO	Monthly	Jan 2025
PH-01	Physical Access — Data Centre	Access control logs + CCTV availability confirmation	Facilities	Quarterly	Jan 2025
PH-02	Visitor Management Log	Signed visitor register	Facilities / Reception	Monthly review	Jan 2025
PH-03	Clean Desk Audit	Audit checklist + findings report	IT Manager / Facilities	Monthly	Jan 2025

Appendix C — Document Review & Approval History

This appendix records the review and approval history of this policy document, providing an audit trail of changes, approvers, and reasons for revision.

Version	Date	Author	Approved By	Change Summary
1.0	January 2021	IT Manager	CEO	Initial policy publication — baseline compliance
1.1	April 2021	IT Manager	IT Manager	Minor corrections to access control section; added remote work p
1.2	September 2021	IT Manager + Legal	CEO	Added data classification section; updated third-party requiremen
2.0	January 2022	IT Manager + Consultant	Board	Major revision — expanded to cover full ECC domain scope; gov
2.1	June 2022	IT Manager	CISO	Updated incident response procedures; added SAMA notification
2.2	October 2022	Security Coordinator	CISO	Added cloud security section; updated MFA requirements to refle
3.0	January 2023	CISO + External Consultant	Board	Comprehensive revision — aligned to NCA ECC-2023; added vu
3.1	May 2023	CISO	CISO	Updated third-party risk tiers; added new vendor assessment for
3.2	August 2023	Security Coordinator	CISO	Corrected glossary entries; updated tooling references (EDR pla
3.3	November 2023	CISO	CEO	Added red team exercise requirements; updated penetration test
4.0	January 2024	CISO + Legal	Board	Major revision — aligned to NCA ECC-2024; added AI/ML securi
4.1	March 2024	CISO	CISO	Updated SAMA reporting timelines following SAMA circular; corr
4.2	June 2024	Security Coordinator	CISO	Added PAM implementation details; updated privileged account
4.3	September 2024	CISO + External Auditor	Board	Post-external-audit revision — addressed 12 audit findings; stren
5.0	January 2025	CISO + Legal + Compliance	Board + CEO	Current version — comprehensive update covering all ECC-2024

END OF DOCUMENT — NCA ECC

Appendix A — Glossary of Cybersecurity Terms

This appendix defines key cybersecurity terms used throughout this document.

Access Control

The process of granting or denying specific requests to obtain and use information and related information processing services, and to enter specific physical facilities.

Advanced Persistent Threat (APT)

A prolonged and targeted cyberattack in which an intruder gains access to a network and remains undetected for an extended period of time in order to steal data or monitor activities.

Asset

Anything that has value to the organisation, its business operations and its continuity, including information resources that support the organisation's mission.

Authentication

The process of verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in an information system.

Business Continuity Plan (BCP)

A documented collection of procedures and information that is developed, compiled and maintained in readiness for use in an incident to enable an organisation to continue to deliver its critical activities.

Chief Information Security Officer (CISO)

The executive responsible for an organisation's information and data security. The CISO directs staff in identifying, developing, implementing, and maintaining processes across the enterprise to reduce information and IT risks.

Compliance

Adherence to a set of policies, standards, regulations, or laws that govern the use, handling, and protection of data and information systems.

Cryptography

The practice and study of techniques for securing communication and data in the presence of adversaries.

Cyber Incident

An event that actually or potentially jeopardises the confidentiality, integrity, or availability of an information system or the information the system processes, stores, or transmits.

Cyber Resilience

The ability of an organisation to withstand, adapt to, and recover from cyber incidents while maintaining the continuous delivery of the intended outcome.

Data Classification

The process of organising data into categories that make it easy to retrieve, sort and store for future use and to comply with data-handling policies.

Defence in Depth

An information security strategy that integrates people, technology, and operations capabilities to establish variable barriers across multiple layers of an organisation's information systems.

Digital Forensics

The process of uncovering and interpreting electronic data for use in a court of law or for investigative purposes.

Disaster Recovery Plan (DRP)

A documented process or set of procedures to recover and protect a business IT infrastructure in the event of a disaster.

Encryption

The process of converting information or data into a code, especially to prevent unauthorised access.

Endpoint

Any remote computing device that communicates back and forth with a network to which it is connected, including laptops, desktops, mobile phones, tablets, and servers.

Firewall

A network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules.

Gap Analysis

An assessment that compares the current state of an organisation's cybersecurity posture against a desired state or regulatory requirement.

Governance

The processes that ensure the effective and efficient use of IT in enabling an organisation to achieve its goals, including the policies and controls that direct and oversee cybersecurity.

Identity and Access Management (IAM)

A framework of business processes, policies, and technologies that facilitates the management of electronic or digital identities and their access rights.

Incident Response Plan (IRP)

A set of instructions to help IT staff detect, respond to, and recover from network security incidents.

Information Security Management System (ISMS)

A set of policies and procedures for systematically managing an organisation's sensitive data and information assets.

Intrusion Detection System (IDS)

A device or software application that monitors a network or systems for malicious activity or policy violations.

Intrusion Prevention System (IPS)

A network security tool that continuously monitors a network for malicious activity and takes action to prevent it.

Key Performance Indicator (KPI)

A measurable value that demonstrates how effectively an organisation is achieving key business or security objectives.

Least Privilege

The principle that a user should be given the minimum levels of access — or permissions — needed to perform their job functions.

Malware

Software that is specifically designed to disrupt, damage, or gain unauthorised access to a computer system.

Multi-Factor Authentication (MFA)

An authentication method that requires the user to provide two or more verification factors to gain access to a resource.

Network Segmentation

The practice of splitting a computer network into subnetworks, each being a network segment to improve security and performance.

Patch Management

The process of distributing and applying updates to software to fix vulnerabilities, bugs, and other issues.

Penetration Testing

A simulated cyberattack against your computer system to check for exploitable vulnerabilities.

Phishing

A type of social engineering attack often used to steal user data, including login credentials and credit card numbers.

Privileged Access Management (PAM)

A cybersecurity solution that helps organisations control, manage, and monitor access by privileged users, accounts, and credentials.

Ransomware

A type of malicious software designed to block access to a computer system until a sum of money is paid.

Recovery Point Objective (RPO)

The maximum acceptable amount of data loss measured in time that is acceptable after a recovery from a disaster or similar event.

Recovery Time Objective (RTO)

The maximum acceptable time after a disaster that a system, application, or function can be offline before the business suffers unacceptable consequences.

Risk Appetite

The amount and type of risk that an organisation is prepared to accept in order to achieve its objectives.

Risk Assessment

The overall process of risk identification, risk analysis, and risk evaluation.

SAMA CSF

The Saudi Central Bank Cyber Security Framework, a mandatory framework applicable to all financial entities regulated by SAMA.

Security Information and Event Management (SIEM)

A solution that helps organisations detect, analyse, and respond to security threats before they harm business operations.

Security Operations Centre (SOC)

A centralised function within an organisation employing people, processes, and technology to continuously monitor and improve an organisation's security posture.

Social Engineering

The use of deception to manipulate individuals into divulging confidential or personal information that may be used for fraudulent purposes.

Two-Factor Authentication (2FA)

A type of multi-factor authentication that requires exactly two forms of identification before granting access.

Vulnerability

A weakness in a system, application, network, or process that can be exploited by a threat actor.

Zero Trust

A security model that requires strict identity verification for every person and device trying to access resources on a private network, regardless of whether they are inside or outside the network perimeter.

Appendix B — Control Implementation Evidence Matrix

The following matrix maps each key control to its implementation evidence, responsible owner, testing frequency, and last verified date. This evidence matrix supports internal audit and regulatory examination processes.

Control ID	Control Name	Evidence Type	Owner	Test Frequency	Last Verified
AC-01	Access Control Policy	Policy document + management sign-off	CISO	Annual	Jan 2025
AC-02	User Account Management	IAM system report + access request tickets	IT Manager	Quarterly	Dec 2024
AC-03	Access Review — Standard Users	Completed review forms signed by managers	IT Manager	Quarterly	Dec 2024
AC-04	Access Review — Privileged	PAM session logs + attestation of SOCs	CISO	Monthly	Jan 2025
AC-05	MFA Enforcement	MDM/SSO configuration screenshot + user report	IT Manager	Monthly	Jan 2025
AC-06	Dormant Account Detection	Automated report from AD showing disabled accounts	IT Manager	Automated	Continuous
AC-07	PAM Implementation	PAM platform configuration + CASO access report	CISO	Quarterly	Dec 2024
NW-01	Firewall Configuration Review	Firewall rule export + review sign-off	IT Manager	Quarterly	Oct 2024
NW-02	Network Segmentation	Network diagram + VLAN configuration	IT Manager	Annual	Jan 2025
NW-03	IPS Signature Update	IPS update log + vendor advisory acknowledgement	SOC	Daily	Jan 2025
NW-04	WAF Configuration	WAF rule export + blocked request log	IT Manager	Monthly	Jan 2025
NW-05	VPN Access with MFA	VPN authentication logs + MFA configuration	IT Manager	Quarterly	Jan 2025
EP-01	EDR Deployment	EDR dashboard showing endpoint coverage %	IT Manager	Monthly	Jan 2025
EP-02	Full Disk Encryption	MDM encryption compliance report	IT Manager	Monthly	Jan 2025
EP-03	Patch Compliance — OS	WSUS patch compliance report	IT Manager	Weekly	Jan 2025
EP-04	Patch Compliance — 3rd Party	Patch management tool report	IT Manager	Weekly	Jan 2025
EP-05	USB Restriction	Group Policy configuration export	IT Manager	Quarterly	Jan 2025
SM-01	SIEM Implementation	SIEM platform configuration + SOC Manager sign-off	SOC Manager	Quarterly	Jan 2025
SM-02	Log Retention	Storage configuration + log retention policy	IT Manager	Quarterly	Jan 2025
SM-03	SOC 24/7 Coverage	Shift roster + on-call schedule	SOC Manager	Monthly	Jan 2025
SM-04	Threat Intelligence Integration	IOC feed configuration + daily SOC findings	SOC Manager	Monthly	Jan 2025
VM-01	External Vulnerability Scan	Scan report + remediation tracking	CISO	Weekly	Jan 2025
VM-02	Internal Vulnerability Scan	Scan report + remediation tracking	IT Manager	Weekly	Jan 2025
VM-03	Penetration Test Results	CREST-certified pen test report	CISO	Annual	Sep 2024
VM-04	Red Team Report	Red team findings report + remediation plan	CISO	Bi-annual	Apr 2024
IM-01	Incident Response Plan	Approved IRP document + disaster recovery evidence	CISO	Annual review	Jan 2025
IM-02	Incident Log	Ticketing system incident records	SOC Manager	Ongoing	Continuous
IM-03	IRP Tabletop Exercise	Exercise report + attendee sign-off sheet	CISO	Quarterly	Nov 2024
IM-04	SAMA Incident Report	Submitted SAMA notification letter	CISO + Compliance	Per incident	N/A this period
IM-05	Post-Incident Review	PIR reports for P1/P2 incidents	CISO	Per incident	N/A this period
BU-01	Backup Completion	Backup system logs showing daily job completion	IT Manager	Daily	Jan 2025
BU-02	Backup Restoration Test	Test restoration log + IT Manager sign-off	IT Manager	Monthly	Dec 2024

BU-03	Offsite Backup Verification	Cloud backup portal showing offsite storage	IT Manager	Weekly	Jan 2025
BU-04	Backup Encryption	Backup configuration showing encryption enabled	IT Manager	Quarterly	Jan 2025
TP-01	Vendor Risk Assessment	Completed vendor questionnaire + ISO assessment report	Legal	Annual	Various 2024
TP-02	Vendor Contracts — Cyber	Contract extract showing cybersecurity schedule	Legal	At contract signing	Various 2024
TP-03	Third-Party Access Review	Access review report for vendor accounts	IT Manager	Monthly	Jan 2025
CL-01	Cloud Security Review	CSPM tool report + CIS benchmark compliance	IT Manager	Quarterly	Dec 2024
CL-02	Cloud MFA Enforcement	Cloud platform MFA configuration manager	IT Manager	Monthly	Jan 2025
AW-01	Security Awareness Training	LMS completion report (≥90% target)	HR / CISO	Annual	Dec 2024
AW-02	Phishing Simulation	Simulation platform report (click rate, completion)	CISO	Monthly	Jan 2025
PH-01	Physical Access — Data Centre	Access control logs + CCTV availability confirmation	Facilities	Quarterly	Jan 2025
PH-02	Visitor Management Log	Signed visitor register	Facilities / Reception	Monthly review	Jan 2025
PH-03	Clean Desk Audit	Audit checklist + findings report	IT Manager / Facilities	Monthly	Jan 2025